CODEX SECURITY

Outplaying attackers

Penetration Test Report

Web application and API assessment

Client: Example Co. (fictional)

Target: portal.example.test

Test window: 3 - 14 March 2026

Report version: 1.0 | Classification: Confidential

1	2	3	2
Critical	High	Medium	Low

SAMPLE - synthetic report written for demonstration. It contains no real client data.

codexsecurity.co | contact@codexsecurity.co

1. Executive summary

Codex Security was engaged by Example Co. to test the customer portal and its public API between 3 and 14 March 2026. The test was manual and followed the OWASP Web Security Testing Guide and the OWASP API Security Top 10. Testers worked as an anonymous visitor, a standard customer and a customer in a second tenant.

Overall risk: High. One critical flaw lets any signed-in customer read other customers' invoices, including bank details. Two high-risk issues allow account takeover paths and privilege escalation. All findings have a clear fix, and the critical issue can be closed in under a day of engineering time.

Severity	Count	What it means
Critical	1	Exploitable now, serious business impact. Fix immediately.
High	2	Likely exploitable, significant impact. Fix within 2 weeks.
Medium	3	Exploitable with conditions. Fix within 90 days.
Low	2	Hardening and defence in depth.

Key recommendations

1. Enforce object-level authorisation on every API route that takes an identifier (A-01).
2. Add rate limiting and lockout to sign-in and password reset (A-02).
3. Validate the role on the server for administrative actions (A-03).
4. Schedule a retest once fixes ship; the retest letter in section 6 is written for auditors.

2. Scope and method

Item	Detail
In scope	portal.example.test, api.example.test (production-like staging)
Out of scope	Third-party payment provider, denial-of-service testing, social engineering
Accounts	Anonymous, Customer A (tenant 1), Customer B (tenant 2), Admin (read-only demo)
Standards	OWASP WSTG, OWASP API Security Top 10, CVSS v3.1 scoring
Authorisation	Written permission signed by the system owner before testing began

Risk ratings combine CVSS v3.1 base score with business context. Every finding below includes the request that proves it, the attacker impact and the exact fix.

3. Findings summary

ID	Finding	Severity	CVSS	Status
A-01	Any user can read other customers' invoices (IDOR)	Critical	9.1	Fixed, verified
A-02	No rate limit on sign-in and password reset	High	8.1	Fixed, verified
A-03	Admin actions trust a client-side role flag	High	8.8	Fixed, verified
A-04	Session cookie missing SameSite attribute	Medium	5.4	Open
A-05	Verbose errors expose stack traces	Medium	5.3	Fixed, verified
A-06	Outdated JavaScript library with known XSS	Medium	6.1	Open
A-07	Missing security headers (CSP, HSTS)	Low	3.7	Open
A-08	Server version banner disclosed	Low	2.6	Fixed, verified

4. Detailed finding

A-01 - Any user can read other customers' invoices

Severity	Critical	CVSS 3.1	9.1 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Category	Broken access control (IDOR)	Affected	GET /api/v2/invoices/{id}

Description

The invoice endpoint confirms that the caller is signed in but never checks that the invoice belongs to the caller's company. Changing the numeric invoice ID in the URL returns another customer's invoice.

Proof of concept (Customer A, tenant 1, requesting an invoice owned by tenant 2)

```
GET /api/v2/invoices/48213 HTTP/1.1
Host: api.example.test
Authorization: Bearer eyJ...[customer A token]

HTTP/1.1 200 OK
{ "invoice": 48213, "tenant": "t-0932",
  "total": "EUR 12,480.00",
  "billing_email": "f***@customer-b.example",
  "iban": "DE89 **** **** **** 4321" }
```

Impact

A trial user can enumerate invoice numbers and download invoices of every customer, including company names, amounts, billing emails and bank account numbers. This is a reportable personal-data exposure under GDPR.

Recommended fix

Look invoices up by both invoice ID and the signed-in user's tenant ID, and return 404 on a mismatch. Use non-sequential identifiers as defence in depth, and add an automated cross-tenant test to the CI pipeline so the regression cannot return.

Retest result: fixed. Requests for other tenants' invoices now return 404. Verified on 2 April 2026.

5. Remediation roadmap

Timeframe	Action	Findings
Within 24 hours	Deploy ownership check on invoice and related object endpoints	A-01
Within 2 weeks	Rate limiting and lockout; server-side role validation	A-02, A-03
Within 90 days	Cookie attributes, error handling, library upgrade	A-04, A-05, A-06
Next release	Security headers and banner removal	A-07, A-08

6. Retest letter

To whom it may concern,

Codex Security retested the findings in this report on 2 April 2026 against portal.example.test. Of eight findings, five were confirmed fixed (A-01, A-02, A-03, A-05, A-08). Three medium and low findings (A-04, A-06, A-07) remain open and are accepted by the client with a remediation date of 30 June 2026.

The critical and high findings no longer reproduce. This letter may be shared with auditors as evidence of independent testing for SOC 2, ISO 27001 or PCI DSS purposes.

Lead penetration tester, Codex Security
codexsecurity.co

This is a synthetic sample. Names, hosts, data and dates are fictional. A real report is written for your systems after a scoping call and a signed authorisation.